



CONSENSUS ASSESSMENTS INITIATIVE QUESTIONNAIRE v4.0.3

Question ID	Question	CSP CAIQ Answer	SSRM Control Ownership	CSP Implementation Description (Optional/Recommended)	CSC Responsibilities (Optional/Recommended)	CCM Control ID	CCM Control Specification	CCM Control Title	CCM Domain Title
A&A-01.1	Are audit and assurance policies, procedures, and standards established, documented, approved, communicated, applied, evaluated, and maintained?	Yes		Nuestra Norma de Auditoría del SGSI describe el proceso integral de auditoría, desde la definición anual del alcance y objetivos hasta la ejecución, comunicación de hallazgos y seguimiento de los planes de acción. Adjunto: NO-SI-16- Auditoría del SGSI_v2.1_2024-11-27.pdf		A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually.	Audit and Assurance Policy and Procedures	Audit & Assurance
A&A-01.2	Are audit and assurance policies, procedures, and standards reviewed and updated at least annually?	Yes		Nuestras políticas, procedimientos y estándares de auditoría y aseguramiento son revisados y actualizados regularmente conforme a nuestra Norma de Gestión Documental del SGSI. Específicamente, el plan de auditoría de nuestro Sistema de Gestión de Seguridad de la Información (SGSI) se elabora y planifica al menos una vez al año, tal como se detalla en la Norma de Auditoría del SGSI (NO-SI-16). Adjunto: - NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf, - NO-SI-16- Auditoría del SGSI_v2.1_2024-11-27.pdf					
A&A-02.1	Are independent audit and assurance assessments conducted according to relevant standards at least annually?	Yes		Adjunto: NO-SI-16- Auditoría del SGSI_v2.1_2024-11-27.pdf		A&A-02	Conduct independent audit and assurance assessments according to relevant standards at least annually.	Independent Assessments	
A&A-03.1	Are independent audit and assurance assessments performed according to risk-based plans and policies?	Yes		Adjunto: NO-SI-16- Auditoría del SGSI_v2.1_2024-11-27.pdf		A&A-03	Perform independent audit and assurance assessments according to risk-based plans and policies.	Risk Based Planning Assessment	
A&A-04.1	Is compliance verified regarding all relevant standards, regulations, legal/contractual, and statutory requirements applicable to the audit?	Yes		En INTIZA, la verificación del cumplimiento con todos los estándares, regulaciones y requisitos legales/contractuales aplicables es fundamental para nuestra postura de seguridad. Nuestra Política de Auditoría: NO-SI-16- Auditoría del SGSI_v2.1_2024-11-27.pdf		A&A-04	Verify compliance with all relevant standards, regulations, legal/contractual, and statutory requirements applicable to the audit.	Requirements Compliance	
A&A-05.1	Is an audit management process defined and implemented to support audit planning, risk analysis, security control assessments, conclusions, remediation schedules, report generation, and reviews of past reports and supporting evidence?	Yes				A&A-05	Define and implement an Audit Management process to support audit planning, risk analysis, security control assessment, conclusion, remediation schedules, report generation, and review of past reports and supporting evidence.	Audit Management Process	
A&A-06.1	Is a risk-based corrective action plan to remediate audit findings established, documented, approved, communicated, applied, evaluated, and maintained?	Yes		INTIZA cuenta con un plan de acción correctivo basado en riesgos para remediar los hallazgos de auditoría. La "Norma de Auditoría del SGSI" establece que el sector auditado debe establecer planes de acción para solucionar los hallazgos de auditoría. Nuestra Norma de Auditoría del SGSI establece explícitamente que el área de Seguridad de la Información es responsable del seguimiento de los planes de acción asociados a los hallazgos de auditoría. También con		A&A-06	Establish, document, approve, communicate, apply, evaluate and maintain a risk-based corrective action plan to remediate audit findings, review and report remediation status to relevant stakeholders.	Remediation	
A&A-06.2	Is the remediation status of audit findings reviewed and reported to relevant stakeholders?	Yes		Nuestro Sistema de Gestión de Seguridad de la Información (SGSI) está certificado bajo la norma ISO/IEC 27001:2022, lo que valida la existencia y eficacia de estos controles. La Política de Seguridad de la Información (PO-SI-01) y la Norma de Desarrollo Seguro (NO-SI-21) definen					
AIS-01.1	Are application security policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained to guide appropriate planning, delivery, and support of the organization's application security capabilities?	Yes		Adjunto: - NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf		AIS-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for application security to provide guidance to the appropriate planning, delivery and support of the organization's application security capabilities. Review and update the policies and procedures at least annually.	Application and Interface Security Policy and Procedures	
AIS-01.2	Are application security policies and procedures reviewed and updated at least annually?	Yes							
AIS-02.1	Are baseline requirements to secure different applications established, documented, and maintained?	Yes		Integramos la seguridad desde las etapas iniciales del ciclo de vida del desarrollo de software, definiendo requisitos específicos en la planificación y diseño de cada proyecto. Desde requisitos de diseño como controles de acceso. La Norma de Gestión de Demanda y Capacidad establece la utilización de métricas para evaluar objetivamente el funcionamiento de nuestra tecnología.		AIS-02	Establish, document and maintain baseline requirements for securing different applications.	Application Security Baseline Requirements	
AIS-03.1	Are technical and operational metrics defined and implemented according to business objectives, security requirements, and compliance obligations?	Yes				AIS-03	Define and implement technical and operational metrics in alignment with business objectives, security requirements, and compliance obligations.	Application Security Metrics	

AIS-04.1	Is an SDLC process defined and implemented for application design, development, deployment, and operation per organizationally designed security requirements?	Yes		Nuestra Norma de Desarrollo Seguro establece lineamientos y responsabilidades para garantizar la seguridad desde la definición de procesos y análisis de requerimientos, hasta el diseño, implementación, pruebas y despliegue.	AIS-04	Define and implement a SDLC process for application design, development, deployment, and operation in accordance with security requirements defined by the organization.	Secure Application Design and Development	Application & Interface Security
AIS-05.1	Does the testing strategy outline criteria to accept new information systems, upgrades, and new versions while ensuring application security, compliance adherence, and organizational speed of delivery goals?	Yes		Antes de la puesta en producción, todas las aplicaciones y sistemas pasan por pruebas exhaustivas, incluyendo pruebas dinámicas de seguridad, análisis de vulnerabilidades y pruebas de penetración semestrales.		Implement a testing strategy, including criteria for acceptance of new information systems, upgrades and new versions, which provides application security assurance and maintains compliance while enabling organizational speed of delivery goals. Automate when applicable and possible.	Automated Application Security Testing	
AIS-05.2	Is testing automated when applicable and possible?	Yes			AIS-05			
AIS-06.1	Are strategies and capabilities established and implemented to deploy application code in a secure, standardized, and compliant manner?	Yes				Establish and implement strategies and capabilities for secure, standardized, and compliant application deployment. Automate where possible.	Automated Secure Application Deployment	
AIS-06.2	Is the deployment and integration of application code automated where possible?	Yes		En INTIZA, el despliegue e integración de código de aplicaciones se gestiona a través de un proceso estructurado y controlado para garantizar la seguridad	AIS-06			
AIS-07.1	Are application security vulnerabilities remediated following defined processes?	Yes	CSP-owned	Este proceso se detalla en nuestra Norma de Gestión de Vulnerabilidades y Parches, cuyo objetivo es identificar, detectar, clasificar y priorizar las vulnerabilidades.		Define and implement a process to remediate application security vulnerabilities, automating remediation when possible.	Application Vulnerability Remediation	
AIS-07.2	Is the remediation of application security vulnerabilities automated when possible?	No		En INTIZA, la detección de vulnerabilidades de seguridad en nuestras aplicaciones y sistemas se realiza mediante escaneos automatizados.	AIS-07			
BCR-01.1	Are business continuity management and operational resilience policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?	Yes		Contamos con una Política de Continuidad de Procesamiento de Datos (PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf) cuyo objetivo es minimizar interrupciones y asegurar un rápido restablecimiento de las operaciones.	BCR-01	Establish, document, approve, communicate, apply, evaluate and maintain business continuity management and operational resilience policies and procedures. Review and update the policies and procedures at least annually.	Business Continuity Management Policy and Procedures	Business Continuity
BCR-01.2	Are the policies and procedures reviewed and updated at least annually?	Yes						
BCR-02.1	Are criteria for developing business continuity and operational resiliency strategies and capabilities established based on business disruption and risk impacts?	Yes			BCR-02	Determine the impact of business disruptions and risks to establish criteria for developing business continuity and operational resilience strategies and capabilities.	Risk Assessment and Impact Analysis	
BCR-03.1	Are strategies developed to reduce the impact of, withstand, and recover from business disruptions in accordance with risk appetite?	Yes		Nuestra Política de Continuidad de Procesamiento de Datos provee un marco exhaustivo para minimizar la probabilidad de interrupciones y garantizar la recuperación.	BCR-03	Establish strategies to reduce the impact of, withstand, and recover from business disruptions within risk appetite.	Business Continuity Strategy	
BCR-04.1	Are operational resilience strategies and capability results incorporated to establish, document, approve, communicate, apply, evaluate, and maintain a business continuity plan?	Yes			BCR-04	Establish, document, approve, communicate, apply, evaluate and maintain a business continuity plan based on the results of the operational resilience strategies and capabilities.	Business Continuity Planning	
BCR-05.1	Is relevant documentation developed, identified, and acquired to support business continuity and operational resilience plans?	Yes			BCR-05	Develop, identify, and acquire documentation that is relevant to support the business continuity and operational resilience programs. Make the documentation available to authorized stakeholders and review periodically.	Documentation	
BCR-05.2	Is business continuity and operational resilience documentation available to authorized stakeholders?	Yes						
BCR-05.3	Is business continuity and operational resilience documentation reviewed periodically?	Yes		El Plan de Continuidad de Procesamiento de Datos de INTIZA se mantiene mediante revisiones y actualizaciones anuales para asegurar su eficacia.				
BCR-06.1	Are the business continuity and operational resilience plans exercised and tested at least annually and when significant changes occur?	Yes			BCR-06	Exercise and test business continuity and operational resilience plans at least annually or upon significant changes.	Business Continuity Exercises	

BCR-07.1	Do business continuity and resilience procedures establish communication with stakeholders and participants?	Yes	La Política de Continuidad de Procesamiento de Datos (PO-TI-01-Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf) detalla un	BCR-07	Establish communication with stakeholders and participants in the course of business continuity and resilience procedures.	Communication	Management and Operational Resilience
BCR-08.1	Is cloud data periodically backed up?	Yes	Se efectúan resguardos diarios de la totalidad de la información de nuestros clientes, los cuales son de tipo incremental. Además, mantenemos una copia de seguridad completa semanal para complementar estos resguardos. Adjunto: NO-SI-15 Resguardo y Recupero de la Información_2024-07-16_v1.1.pdf,	BCR-08	Periodically backup data stored in the cloud. Ensure the confidentiality, integrity and availability of the backup, and verify data restoration from backup for resiliency.	Backup	
BCR-08.2	Is the confidentiality, integrity, and availability of backup data ensured?	Yes					
BCR-08.3	Can backups be restored appropriately for resiliency?	Yes	En INTIZA, las copias de seguridad pueden ser restauradas apropiadamente para asegurar la resiliencia operativa. Adjunto: NO-SI-15 Resguardo y Recupero de la Información_2024-07-16_v1.1.pdf,				
BCR-09.1	Is a disaster response plan established, documented, approved, applied, evaluated, and maintained to ensure recovery from natural and man-made disasters?	Yes	Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf	BCR-09	Establish, document, approve, communicate, apply, evaluate and maintain a disaster response plan to recover from natural and man-made disasters. Update the plan at least annually or upon significant changes.	Disaster Response Plan	
BCR-09.2	Is the disaster response plan updated at least annually, and when significant changes occur?	Yes	Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf				
BCR-10.1	Is the disaster response plan exercised annually or when significant changes occur?	Yes	Los planes de continuidad se prueban al menos una vez al año para garantizar que estén actualizados y sean efectivos, y que todo el personal relevante esté al	BCR-10	Exercise the disaster response plan annually or upon significant changes, including if possible local emergency authorities.	Response Plan Exercise	
BCR-10.2	Are local emergency authorities included, if possible, in the exercise?	Yes					
BCR-11.1	Is business-critical equipment supplemented with redundant equipment independently located at a reasonable minimum distance in accordance with applicable industry standards?	Yes	Utilizamos sitios alternativos de procesamiento de información en ubicaciones geográficamente separadas y distintas a las utilizadas para la gestión diaria, y realizamos operaciones de recuperación fuera del sitio principal.	BCR-11	Supplement business-critical equipment with redundant equipment independently located at a reasonable minimum distance in accordance with applicable industry standards.	Equipment Redundancy	
CCC-01.1	Are risk management policies and procedures associated with changing organizational assets including applications, systems, infrastructure, configuration, etc., established, documented, approved, communicated, applied, evaluated and maintained (regardless of whether asset management is internal or external)?	Yes	INTIZA cuenta con políticas y procedimientos robustos para la gestión de riesgos asociados a cambios en los activos organizacionales, incluyendo aplicaciones, sistemas, infraestructura y configuración, tanto internos como externos. Adjunto: NO-SI-04- Gestión de Riesgo del SGSI_2024-11-21_v3.0.pdf	CCC-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for managing the risks associated with applying changes to organization assets, including application, systems, infrastructure, configuration, etc., regardless of whether the assets are managed internally or externally (i.e., outsourced). Review and update the policies and procedures at least annually.	Change Management Policy and Procedures	
CCC-01.2	Are the policies and procedures reviewed and updated at least annually?	Yes					
CCC-02.1	Is a defined quality change control, approval and testing process (with established baselines, testing, and release standards) followed?	Yes	Adjunto: NO-TI-04 Gestión de Cambios_v2.2_2025-10-28.pdf	CCC-02	Follow a defined quality change control, approval and testing process with established baselines, testing, and release standards.	Quality Testing	
CCC-03.1	Are risks associated with changing organizational assets (including applications, systems, infrastructure, configuration, etc.) managed, regardless of whether asset management occurs internally or externally (i.e., outsourced)?	Yes	Norma de Gestión de Riesgos del SGSI (NO-SI-04) establecen que cualquier cambio significativo en los activos de TI o en el entorno de negocio requiere una evaluación de riesgos para revisar y ajustar las medidas de seguridad. Adjunto: NO-SI-04- Gestión de Riesgo del SGSI_2024-11-21_v3.0.pdf	CCC-03	Manage the risks associated with applying changes to organization assets, including application, systems, infrastructure, configuration, etc., regardless of whether the assets are managed internally or externally (i.e., outsourced).	Change Management Technology	
CCC-04.1	Is the unauthorized addition, removal, update, and management of organization assets restricted?	Yes	La Norma de Gestión de Activos de la Información regula el inventario y clasificación de activos de TI y de información, y establece procedimientos	CCC-04	Restrict the unauthorized addition, removal, update, and management of organization assets.	Unauthorized Change Protection	

CCC-05.1	Are provisions to limit changes that directly impact CSC-owned environments and require tenants to authorize requests explicitly included within the service level agreements (SLAs) between CSPs and CSCs?	NA	Intiza es una aplicación SaaS. Intiza no accede a entornos propiedad del cliente.	CCC-05	Include provisions limiting changes directly impacting CSCs owned environments/tenants to explicitly authorized requests within service level agreements between CSPs and CSCs.	Change Agreements
CCC-06.1	Are change management baselines established for all relevant authorized changes on organizational assets?	Yes	Adjunto: NO-TI-04 Gestión de Cambios_v2.2_2025-10-28.pdf	CCC-06	Establish change management baselines for all relevant authorized changes on organization assets.	Change Management Baseline
CCC-07.1	Are detection measures implemented with proactive notification if changes deviate from established baselines?	Yes	Si un evento se desvía del rango establecido, el sistema emite automáticamente una alerta por correo electrónico a un grupo predeterminado.	CCC-07	Implement detection measures with proactive notification in case of changes deviating from the established baseline.	Detection of Baseline Deviation
CCC-08.1	Is a procedure implemented to manage exceptions, including emergencies, in the change and configuration process?	Yes	Nuestra Norma de Gestión de Cambios establece un marco para manejar distintos tipos de cambios, incluyendo los "Cambios de emergencia". Estos últimos se caracterizan por su alto impacto y urgencia, requiriendo una respuesta inmediata. Nuestra norma de excepciones está alineada con los requisitos de la gestión de riesgos. Adjunto: NO-SI-08 Excepciones de Seguridad de la Información_2024-11-27_v2.1.pdf	CCC-08	'Implement a procedure for the management of exceptions, including emergencies, in the change and configuration process. Align the procedure with the requirements of GRC-04: Policy Exception Process.'	Exception Management
CCC-08.2	'Is the procedure aligned with the requirements of the GRC-04: Policy Exception Process?'	Yes				
CCC-09.1	Is a process to proactively roll back changes to a previously known "good state" defined and implemented in case of errors or security concerns?	Yes		CCC-09	Define and implement a process to proactively roll back changes to a previous known good state in case of errors or security concerns.	Change Restoration
CEK-01.1	Are cryptography, encryption, and key management policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf,	CEK-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for Cryptography, Encryption and Key Management. Review and update the policies and procedures at least annually.	Encryption and Key Management Policy and Procedures
CEK-01.2	Are cryptography, encryption, and key management policies and procedures reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan 1 vez al año.			
CEK-02.1	Are cryptography, encryption, and key management roles and responsibilities defined and implemented?	Yes	Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf,	CEK-02	Define and implement cryptographic, encryption and key management roles and responsibilities.	CEK Roles and Responsibilities
CEK-03.1	Are data at-rest and in-transit cryptographically protected using cryptographic libraries certified to approved standards?	Yes	Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf	CEK-03	Provide cryptographic protection to data at-rest and in-transit, using cryptographic libraries certified to approved standards.	Data Encryption
CEK-04.1	Are appropriate data protection encryption algorithms used that consider data classification, associated risks, and encryption technology usability?	Yes	Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf,	CEK-04	Use encryption algorithms that are appropriate for data protection, considering the classification of data, associated risks, and usability of the encryption technology.	Encryption Algorithm
CEK-05.1	Are standard change management procedures established to review, approve, implement and communicate cryptography, encryption, and key management technology changes that accommodate internal and external sources?	Yes	Es un requisito innegociable que todo cambio, sin importar su origen, sea revisado por el área de Seguridad de la Información antes de su implementación en producción. Adjunto: NO-TI-04 Gestión de Cambios_v2.2_2025-10-28.pdf	CEK-05	Establish a standard change management procedure, to accommodate changes from internal and external sources, for review, approval, implementation and communication of cryptographic, encryption and key management technology changes.	Encryption Change Management
CEK-06.1	Are changes to cryptography-, encryption- and key management-related systems, policies, and procedures, managed and adopted in a manner that fully accounts for downstream effects of proposed changes, including residual risk, cost, and benefits analysis?	Yes	Adjunto: NO-TI-04 Gestión de Cambios_v2.2_2025-10-28.pdf	CEK-06	Manage and adopt changes to cryptography-, encryption-, and key management-related systems (including policies and procedures) that fully account for downstream effects of proposed changes, including residual risk, cost, and benefits analysis.	Encryption Change Cost Benefit Analysis
CEK-07.1	Is a cryptography, encryption, and key management risk program established and maintained that includes risk assessment, risk treatment, risk context, monitoring, and feedback provisions?	Yes	En INTIZA hemos establecido y mantenemos un robusto programa de gestión de riesgos para la criptografía, el cifrado y la administración de claves, el cual está plenamente integrado en nuestro Sistema de Gestión de Seguridad de la Información (SGSI) u	CEK-07	Establish and maintain an encryption and key management risk program that includes provisions for risk assessment, risk treatment, risk context, monitoring, and feedback.	Encryption Risk Management
CEK-08.1	Are CSPs providing CSCs with the capacity to manage their own data encryption keys?	Yes	Utilizamos Microsoft Azure como nuestro proveedor de infraestructura en la nube y la gestión de las claves de cifrado para los datos almacenados en la nube está delegado a este proveedor.	CEK-08	CSPs must provide the capability for CSCs to manage their own data encryption keys.	CSC Key Management Capability

CEK-09.1	Are encryption and key management systems, policies, and processes audited with a frequency proportional to the system's risk exposure, and after any security event?	Yes	Seguridad de la Información es responsable de controlar y monitorear continuamente la gestión de estas claves, asegurando su salvaguarda contra modificación, pérdida o divulgación no autorizada. Nuestros sistemas utilizan un proceso de	CEK-09	Audit encryption and key management systems, policies, and processes with a frequency that is proportional to the risk exposure of the system with audit occurring preferably continuously but at least annually and after any security event(s).	Encryption and Key Management Audit
CEK-09.2	Are encryption and key management systems, policies, and processes audited (preferably continuously but at least annually)?	Yes	Seguridad de la Información es responsable de controlar y monitorear continuamente la gestión de estas claves, asegurando su salvaguarda contra modificación, pérdida o divulgación no autorizada. Nuestros sistemas utilizan un proceso de			
CEK-10.1	Are cryptographic keys generated using industry-accepted and approved cryptographic libraries that specify algorithm strength and random number generator specifications?	Yes	Nuestra Norma de Cifrado de la Información establece claramente el uso de algoritmos reconocidos en la industria. Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf,	CEK-10	Generate Cryptographic keys using industry accepted cryptographic libraries specifying the algorithm strength and the random number generator used.	Key Generation
CEK-11.1	Are private keys provisioned for a unique purpose managed, and is cryptography secret?	Yes	Las claves son generadas para su utilización en diferentes aplicaciones o por cada unidad de base de datos, lo que indica su propósito específico. Se	CEK-11	Manage cryptographic secret and private keys that are provisioned for a unique purpose.	Key Purpose
CEK-12.1	Are cryptographic keys rotated based on a cryptoperiod calculated while considering information disclosure risks and legal and regulatory requirements?	Yes	Solo el Administrador de la Infraestructura tiene acceso a visualizar las claves de cifrado. Estas se almacenan de forma segura en Microsoft Azure y se rotan	CEK-12	Rotate cryptographic keys in accordance with the calculated cryptoperiod, which includes provisions for considering the risk of information disclosure and legal and regulatory requirements.	Key Rotation
CEK-13.1	Are cryptographic keys revoked and removed before the end of the established cryptoperiod (when a key is compromised, or an entity is no longer part of the organization) per defined, implemented, and evaluated processes, procedures, and technical measures to include legal and regulatory requirement provisions?	Yes	En INTIZA hemos establecido procesos, procedimientos y medidas técnicas robustas para la gestión del ciclo de vida de nuestras claves criptográficas, incluyendo su revocación y eliminación. En caso de compromiso de una clave, activamos nuestra Norma de Gestión de Incidentes de Seguridad Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf,	CEK-13	Define, implement and evaluate processes, procedures and technical measures to revoke and remove cryptographic keys prior to the end of its established cryptoperiod, when a key is compromised, or an entity is no longer part of the organization, which include provisions for legal and regulatory requirements.	Key Revocation
CEK-14.1	Are processes, procedures and technical measures to destroy unneeded keys defined, implemented and evaluated to address key destruction outside secure environments, revocation of keys stored in hardware security modules (HSMs), and include applicable legal and regulatory requirement provisions?	Yes		CEK-14	Define, implement and evaluate processes, procedures and technical measures to destroy keys stored outside a secure environment and revoke keys stored in Hardware Security Modules (HSMs) when they are no longer needed, which include provisions for legal and regulatory requirements.	Key Destruction
CEK-15.1	Are processes, procedures, and technical measures to create keys in a pre-activated state (i.e., when they have been generated but not authorized for use) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?	NA	Intiza no genera claves en estado preactivado.	CEK-15	Define, implement and evaluate processes, procedures and technical measures to create keys in a pre-activated state when they have been generated but not authorized for use, which include provisions for legal and regulatory requirements.	Key Activation
CEK-16.1	Are processes, procedures, and technical measures to monitor, review and approve key transitions (e.g., from any state to/from suspension) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?	Yes	Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf	CEK-16	Define, implement and evaluate processes, procedures and technical measures to monitor, review and approve key transitions from any state to/from suspension, which include provisions for legal and regulatory requirements.	Key Suspension
CEK-17.1	Are processes, procedures, and technical measures to deactivate keys (at the time of their expiration date) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?	Yes	Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf	CEK-17	Define, implement and evaluate processes, procedures and technical measures to deactivate keys at the time of their expiration date, which include provisions for legal and regulatory requirements.	Key Deactivation
CEK-18.1	Are processes, procedures, and technical measures to manage archived keys in a secure repository (requiring least privilege access) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?	Yes	El acceso a estas claves criptográficas está estrictamente restringido a la menor cantidad de custodios necesarios, garantizando el principio de menor privilegio. Además, existe un proceso formal de administración de	CEK-18	Define, implement and evaluate processes, procedures and technical measures to manage archived keys in a secure repository requiring least privilege access, which include provisions for legal and regulatory requirements.	Key Archival
CEK-19.1	Are processes, procedures, and technical measures to use compromised keys to encrypt information in specific scenarios (e.g., only in controlled circumstances and thereafter only for data decryption and never for encryption) defined, implemented, and evaluated to include legal and regulatory requirement provisions?	NA	No se utilizan claves comprometidas para cifrar información en escenarios específicos.	CEK-19	Define, implement and evaluate processes, procedures and technical measures to use compromised keys to encrypt information only in controlled circumstance, and thereafter exclusively for decrypting data and never for encrypting data, which include provisions for legal and regulatory requirements.	Key Compromise

CEK-20.1	Are processes, procedures, and technical measures to assess operational continuity risks (versus the risk of losing control of keying material and exposing protected data) being defined, implemented, and evaluated to include legal and regulatory requirement provisions?	Yes	Nuestra Política de Continuidad de Procesamiento de Datos y la Norma de Gestión de Riesgos del SGSI establecen un marco para identificar, analizar y evaluar sistemáticamente los riesgos de seguridad de la información. Adjunto: - PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf	CEK-20	Define, implement and evaluate processes, procedures and technical measures to assess the risk to operational continuity versus the risk of the keying material and the information it protects being exposed if control of the keying material is lost, which include provisions for legal and regulatory requirements.	Key Recovery
CEK-21.1	Are key management system processes, procedures, and technical measures being defined, implemented, and evaluated to track and report all cryptographic materials and status changes that include legal and regulatory requirements provisions?	Yes	Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf	CEK-21	Define, implement and evaluate processes, procedures and technical measures in order for the key management system to track and report all cryptographic materials and changes in status, which include provisions for legal and regulatory requirements.	Key Inventory Management
DCS-01.1	Are policies and procedures for the secure disposal of equipment used outside the organization's premises established, documented, approved, communicated, enforced, and maintained?	Yes	INTIZA cuenta con políticas y procedimientos bien definidos y documentados para la disposición segura de equipos utilizados tanto dentro como fuera de las instalaciones. Nuestra Norma de Retención y Eliminación de Información establece los lineamientos para garantizar la En INTIZA aplicamos un procedimiento de eliminación de datos que imposibilita su recuperación, incluso si el equipo no es destruido físicamente. Antes de reasignar un equipo a un nuevo usuario, realizamos un borrado seguro de la información almacenada. Esto se logra mediante el uso de herramientas. Todas nuestras políticas y normas se revisan y actualizan 1 vez al año.	DCS-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for the secure disposal of equipment used outside the organization's premises. If the equipment is not physically destroyed a data destruction procedure that renders recovery of information impossible must be applied. Review and update the policies and procedures at least annually.	Off-Site Equipment Disposal Policy and Procedures
DCS-01.2	Is a data destruction procedure applied that renders information recovery information impossible if equipment is not physically destroyed?	Yes				
DCS-01.3	Are policies and procedures for the secure disposal of equipment used outside the organization's premises reviewed and updated at least annually?	Yes				
DCS-02.1	Are policies and procedures for the relocation or transfer of hardware, software, or data/information to an offsite or alternate location established, documented, approved, communicated, implemented, enforced, maintained?	Yes	Solo reasignamos dispositivos móviles que utilizan nuestros colaboradores. Adjunto: NO-SI-26- Seguridad en Dispositivos Móviles_v1.1_02-05-2025.pdf	DCS-02	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for the relocation or transfer of hardware, software, or data/information to an offsite or alternate location. The relocation or transfer request requires the written or cryptographically verifiable authorization. Review and update the policies and procedures at least annually.	Off-Site Transfer Authorization Policy and Procedures
DCS-02.2	Does a relocation or transfer request require written or cryptographically verifiable authorization?	Yes	Toda solicitud de reubicación o transferencia, especialmente aquellas relacionadas con el teletrabajo y la asignación de activos, requiere una autorización formal y documentada. Adjunto: - NO-TI-02- Teletrabajo_V2.1_2025-05-15.pdf, - NO-SI-17 Gestión de Activos de la			
DCS-02.3	Are policies and procedures for the relocation or transfer of hardware, software, or data/information to an offsite or alternate location reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf			
DCS-03.1	Are policies and procedures for maintaining a safe and secure working environment (in offices, rooms, and facilities) established, documented, approved, communicated, enforced, and maintained?	Yes	Nuestra Política de Seguridad de la Información incluye una sección dedicada a la "Seguridad Física aplicada a los Activos de la Información". Esta política exige la implementación de medidas de seguridad física en todos los sitios que poseen o almacenan datos de	DCS-03	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for maintaining a safe and secure working environment in offices, rooms, and facilities. Review and update the policies and procedures at least annually.	Secure Area Policy and Procedures
DCS-03.2	Are policies and procedures for maintaining safe, secure working environments (e.g., offices, rooms) reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf			
DCS-04.1	Are policies and procedures for the secure transportation of physical media established, documented, approved, communicated, enforced, evaluated, and maintained?	NA	Nosotros no hacemos traslado de medios físicos.	DCS-04	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for the secure transportation of physical media. Review and update the policies and procedures at least annually.	Secure Media Transportation

DCS-04.2	Are policies and procedures for the secure transportation of physical media reviewed and updated at least annually?	NA	Nosotros no hacemos traslado de medios físicos.			Policy and Procedures	Datacenter Security
DCS-05.1	Is the classification and documentation of physical and logical assets based on the organizational business risk?	Yes	La clasificación y documentación de los activos físicos y lógicos de INTIZA se basa directamente en el riesgo de negocio de la organización. Contamos con un proceso de clasificación de activos.	DCS-05	Classify and document the physical, and logical assets (e.g., applications) based on the organizational business risk.	Assets Classification	
DCS-06.1	Are all relevant physical and logical assets at all CSP sites cataloged and tracked within a secured system?	Yes	Adjunto: - ME-SI-02 Metodología de Clasificación de Activos de la Información.docx.pdf.	DCS-06	Catalogue and track all relevant physical and logical assets located at all of the CSPs sites within a secured system.	Assets Cataloguing and Tracking	
DCS-07.1	Are physical security perimeters implemented to safeguard personnel, data, and information systems?	Yes	Adjunto: NO-RH-02 Acceso y Control Físico.docx_v2.1_2025-02-28.pdf	DCS-07	Implement physical security perimeters to safeguard personnel, data, and information systems. Establish physical security perimeters between the administrative and business areas and the data storage and processing facilities areas.	Controlled Access Points	
DCS-07.2	Are physical security perimeters established between administrative and business areas, data storage, and processing facilities?	Yes	Las instalaciones de almacenamiento y procesamiento de datos están en Microsoft Azure, nuestro proveedor de servicios en la nube. La seguridad física de estos centros de datos es responsabilidad de Microsoft Azure, un proveedor fuera de nuestra red.				
DCS-08.1	Is equipment identification used as a method for connection authentication?	No	La identificación de equipos no se utiliza como un método de autenticación de conexión por sí mismo en INTIZA.	DCS-08	Use equipment identification as a method for connection authentication.	Equipment Identification	
DCS-09.1	Are solely authorized personnel able to access secure areas, with all ingress and egress areas restricted, documented, and monitored by physical access control mechanisms?	Yes	Adjunto: NO-RH-02 Acceso y Control Físico.docx_v2.1_2025-02-28.pdf	DCS-09	Allow only authorized personnel access to secure areas, with all ingress and egress points restricted, documented, and monitored by physical access control mechanisms. Retain access control records on a periodic basis as deemed appropriate by the organization.	Secure Area Authorization	
DCS-09.2	Are access control records retained periodically, as deemed appropriate by the organization?	Yes	Adjunto: NO-RH-02 Acceso y Control Físico.docx_v2.1_2025-02-28.pdf				
DCS-10.1	Are external perimeter datacenter surveillance systems and surveillance systems at all ingress and egress points implemented, maintained, and operated?	Yes	La seguridad física de estos datacenters, incluyendo los sistemas de vigilancia perimetral externa y los controles en todos los puntos de entrada y salida, es gestionada directamente por Microsoft Azure.	DCS-10	Implement, maintain, and operate datacenter surveillance systems at the external perimeter and at all the ingress and egress points to detect unauthorized ingress and egress attempts.	Surveillance System	
DCS-11.1	Are datacenter personnel trained to respond to unauthorized access or egress attempts?	Yes	La seguridad física de los centros de datos, incluyendo la formación del personal para responder a intentos de acceso o egreso no autorizados, es gestionada directamente por Microsoft Azure.	DCS-11	Train datacenter personnel to respond to unauthorized ingress or egress attempts.	Unauthorized Access Response Training	
DCS-12.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure risk-based protection of power and telecommunication cables from interception, interference, or damage threats at all facilities, offices, and rooms?	Yes	Adjunto: NO-RH-02 Acceso y Control Físico.docx_v2.1_2025-02-28.pdf.	DCS-12	Define, implement and evaluate processes, procedures and technical measures that ensure a risk-based protection of power and telecommunication cables from a threat of interception, interference or damage at all facilities, offices and rooms.	Cabling Security	
DCS-13.1	Are data center environmental control systems designed to monitor, maintain, and test that on-site temperature and humidity conditions fall within accepted industry standards effectively implemented and maintained?	Yes	La seguridad física de los centros de datos, incluyendo los sistemas de monitoreo y mantenimiento de temperatura y humedad, es responsabilidad directa de Microsoft Azure. Esta responsabilidad está sujeta a la disponibilidad de los recursos de Azure.	DCS-13	Implement and maintain data center environmental control systems that monitor, maintain and test for continual effectiveness the temperature and humidity conditions within accepted industry standards.	Environmental Systems	
DCS-14.1	Are utility services secured, monitored, maintained, and tested at planned intervals for continual effectiveness?	Yes	Adjunto: - NO-RH-02 Acceso y Control Físico.docx_v2.1_2025-02-28.pdf, - PO-TI-01- Continuidad de Servicios de TI.docx_v2.1_2025-02-28.pdf.	DCS-14	Secure, monitor, maintain, and test utilities services for continual effectiveness at planned intervals.	Secure Utilities	
DCS-15.1	Is business-critical equipment segregated from locations subject to a high probability of environmental risk events?	Yes	Nuestra infraestructura se aloja en los centros de datos de Microsoft Azure en EE. UU., los cuales poseen certificaciones como ISO 27001 y ISO 27002.	DCS-15	Keep business-critical equipment away from locations subject to high probability for environmental risk events.	Equipment Location	
DSP-01.1	Are policies and procedures established, documented, approved, communicated, enforced, evaluated, and maintained for the classification, protection, and handling of data throughout its lifecycle according to all applicable laws and regulations, standards, and risk level?	Yes	Nuestro Sistema de Gestión de Seguridad de la Información (SGSI) está certificado bajo ISO/IEC 27001:2022, lo que valida la robustez de nuestro marco. La Política de Seguridad de la Información define las directrices generales para garantizar la confidencialidad, integridad y disponibilidad de todos los activos de	DSP-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for the classification, protection and handling of data throughout its lifecycle, and according to all applicable laws and regulations, standards, and risk level. Review and update the policies and procedures at least annually.	Security and Privacy Policy and Procedures	

DSP-01.2	Are data security and privacy policies and procedures reviewed and updated at least annually?	Yes	Nuestra Norma de Gestión Documental del SGSI define plazos específicos para las revisiones de nuestro marco normativo. Específicamente, las políticas y normas se revisan cada dos años. Sin embargo, los procedimientos relacionados con la seguridad y privacidad, clasificados como "Otros Adjunto: NO-SI-19 Retención y Eliminación de información_v2.1_2025-02-25.pdf,			
DSP-02.1	Are industry-accepted methods applied for secure data disposal from storage media so information is not recoverable by any forensic means?	Yes		DSP-02	Apply industry accepted methods for the secure disposal of data from storage media such that data is not recoverable by any forensic means.	Secure Disposal
DSP-03.1	Is a data inventory created and maintained for sensitive and personal information (at a minimum)?	Yes	Adjunto: - PO-SI-02- Protección de Datos Personales_v1.2_13-11-2024.pdf, - PO-SI-01- Seguridad de la información_2024-10-08_v3.0.pdf	DSP-03	Create and maintain a data inventory, at least for any sensitive data and personal data.	Data Inventory
DSP-04.1	Is data classified according to type and sensitivity levels?	Yes	Nos basamos en la "Metodología de Clasificación de Activos de la Información" (ME-SI-02) para identificar	DSP-04	Classify data according to its type and sensitivity level.	Data Classification
DSP-05.1	Is data flow documentation created to identify what data is processed and where it is stored and transmitted?	Yes		DSP-05	Create data flow documentation to identify what data is processed, stored or transmitted where. Review data flow documentation at defined intervals, at least annually, and after any change.	Data Flow Documentation
DSP-05.2	Is data flow documentation reviewed at defined intervals, at least annually, and after any change?	Yes				
DSP-06.1	Is the ownership and stewardship of all relevant personal and sensitive data documented?	Yes	En INTIZA, consideramos todos los datos personales como información confidencial y los tratamos de acuerdo con los lineamientos definidos en nuestro marco normativo. /"PD-SI-02.	DSP-06	Document ownership and stewardship of all relevant documented personal and sensitive data. Perform review at least annually.	Data Ownership and Stewardship
DSP-06.2	Is data ownership and stewardship documentation reviewed at least annually?	Yes				
DSP-07.1	Are systems, products, and business practices based on security principles by design and per industry best practices?	Yes	Integramos la seguridad desde el inicio del ciclo de desarrollo del software, aplicando prácticas de desarrollo seguro, revisiones de código y pruebas	DSP-07	Develop systems, products, and business practices based upon a principle of security by design and industry best practices.	Data Protection by Design and Default
DSP-08.1	Are systems, products, and business practices based on privacy principles by design and according to industry best practices?	Yes	Implementamos controles para la protección de datos personales de acuerdo con los principios de gestión de riesgos y las mejores prácticas de seguridad. Además, en la gestión de proyectos que involucren información	DSP-08	Develop systems, products, and business practices based upon a principle of privacy by design and industry best practices. Ensure that systems' privacy settings are configured by default, according to all applicable laws and regulations.	Data Privacy by Design and Default
DSP-08.2	Are systems' privacy settings configured by default and according to all applicable laws and regulations?	Yes	Nuestras configuraciones de privacidad del sistema están configuradas por defecto y de acuerdo con todas las leyes y regulaciones aplicables.			
DSP-09.1	Is a data protection impact assessment (DPIA) conducted when processing personal data and evaluating the origin, nature, particularity, and severity of risks according to any applicable laws, regulations and industry best practices?	Yes	INTIZA se compromete a proteger los datos personales procesados, almacenados o transmitidos por la organización, asegurando su confidencialidad, integridad y disponibilidad. Adjunto: - PO-SI-02- Protección de Datos Personales_v1.2_13-11-2024.pdf	DSP-09	Conduct a Data Protection Impact Assessment (DPIA) to evaluate the origin, nature, particularity and severity of the risks upon the processing of personal data, according to any applicable laws, regulations and industry best practices.	Data Protection Impact Assessment
DSP-10.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure any transfer of personal or sensitive data is protected from unauthorized access and only processed within scope (as permitted by respective laws and regulations)?	Yes	Adjunto: - PO-SI-02- Protección de Datos Personales_v1.2_13-11-2024.pdf, - PO-SI-01- Seguridad de la información_2024-10-08_v3.0.pdf	DSP-10	Define, implement and evaluate processes, procedures and technical measures that ensure any transfer of personal or sensitive data is protected from unauthorized access and only processed within scope as permitted by the respective laws and regulations.	Sensitive Data Transfer
DSP-11.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to enable data subjects to request access to, modify, or delete personal data (per applicable laws and regulations)?	Yes	Establecemos procesos para la gestión de solicitudes de acceso, rectificación, eliminación y portabilidad de datos personales, de acuerdo con las leyes y regulaciones aplicables, como GDPR y leyes locales de protección de datos. Adjunto:	DSP-11	Define and implement, processes, procedures and technical measures to enable data subjects to request access to, modification, or deletion of their personal data, according to any applicable laws and regulations.	Personal Data Access, Reversal, Rectification and Deletion

Data Security and Privacy Lifecycle Management

DSP-12.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure personal data is processed (per applicable laws and regulations and for the purposes declared to the data subject)?	Yes	Cumplimos con definir, implementar y evaluar procesos, procedimientos y medidas técnicas para asegurar que los datos personales se procesen de acuerdo con las leyes y regulaciones aplicables, y para los propósitos declarados al titular de los datos.	DSP-12	Define, implement and evaluate processes, procedures and technical measures to ensure that personal data is processed according to any applicable laws and regulations and for the purposes declared to the data subject.	Limitation of Purpose in Personal Data Processing
DSP-13.1	Are processes, procedures, and technical measures defined, implemented, and evaluated for the transfer and sub-processing of personal data within the service supply chain (according to any applicable laws and regulations)?	Yes	Nuestra política de Protección de Datos Personales (PO-SI-02) abarca cualquier operación o conjunto de operaciones sobre datos personales, incluyendo la recolección, almacenamiento, uso o circulación.	DSP-13	Define, implement and evaluate processes, procedures and technical measures for the transfer and sub-processing of personal data within the service supply chain, according to any applicable laws and regulations.	Personal Data Sub-processing
DSP-14.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to disclose details to the data owner of any personal or sensitive data access by sub-processors before processing initiation?	NA		DSP-14	Define, implement and evaluate processes, procedures and technical measures to disclose the details of any personal or sensitive data access by sub-processors to the data owner prior to initiation of that processing.	Disclosure of Data Sub-processors
DSP-15.1	Is authorization from data owners obtained, and the associated risk managed, before replicating or using production data in non-production environments?	Yes	INTIZA recolecta exclusivamente aquellos datos que han sido suministrados voluntariamente por sus titulares o que son obtenidos a partir de ellos.	DSP-15	Obtain authorization from data owners, and manage associated risk before replicating or using production data in non-production environments.	Limitation of Production Data Use
DSP-16.1	Do data retention, archiving, and deletion practices follow business requirements, applicable laws, and regulations?	Yes	Adjunto: NO-SI-19 Retención y Eliminación de Información_v2.11_2025-02-25.pdf	DSP-16	Data retention, archiving and deletion is managed in accordance with business requirements, applicable laws and regulations.	Data Retention and Deletion
DSP-17.1	Are processes, procedures, and technical measures defined and implemented to protect sensitive data throughout its lifecycle?	Yes	Disponemos de un marco robusto de procesos, procedimientos y medidas técnicas para proteger los datos sensibles a lo largo de todo su ciclo de vida.	DSP-17	Define and implement, processes, procedures and technical measures to protect sensitive data throughout its lifecycle.	Sensitive Data Protection
DSP-18.1	Does the CSP have in place, and describe to CSCs, the procedure to manage and respond to requests for disclosure of Personal Data by Law Enforcement Authorities according to applicable laws and regulations?	Yes	Adjunto: PO-SI-02- Protección de Datos Personales_v1.2_13-11-2024.pdf	DSP-18	The CSP must have in place, and describe to CSCs the procedure to manage and respond to requests for disclosure of Personal Data by Law Enforcement Authorities according to applicable laws and regulations. The CSP must give special attention to the notification procedure to interested CSCs, unless otherwise prohibited, such as a prohibition under criminal law to preserve confidentiality of a law enforcement investigation.	Disclosure Notification
DSP-18.2	Does the CSP give special attention to the notification procedure to interested CSCs, unless otherwise prohibited, such as a prohibition under criminal law to preserve confidentiality of a law enforcement investigation?	Yes				
DSP-19.1	Are processes, procedures, and technical measures defined and implemented to specify and document physical data locations, including locales where data is processed or backed up?	Yes		DSP-19	Define and implement, processes, procedures and technical measures to specify and document the physical locations of data, including any locations in which data is processed or backed up.	Data Location
GRC-01.1	Are information governance program policies and procedures sponsored by organizational leadership established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	En INTIZA hemos establecido un programa integral de gobierno de la información, cuyas políticas y procedimientos son patrocinados por la Dirección. Toda nuestra documentación normativa del Sistema de Gestión de Seguridad de la Información (SGSI) se elabora, controla, revisa y aprueba bMA-SI-01- Manual SGSI - Sistema de Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental.	GRC-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for an information governance program, which is sponsored by the leadership of the organization. Review and update the policies and procedures at least annually.	Governance Program Policy and Procedures
GRC-01.2	Are the policies and procedures reviewed and updated at least annually?	Yes	Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf			
GRC-02.1	Is there an established formal, documented, and leadership-sponsored enterprise risk management (ERM) program that includes policies and procedures for identification, evaluation, ownership, treatment, and acceptance of cloud security and privacy risks?	Yes	Adjunto: - NO-SI-04- Gestión de Riesgo del SGSI_2024-11-21-v3.0.pdf - NO-SI-27- Norma de Seguridad Cloud.pdf - PO-SI-01- Seguridad de la información_2024-10-08_v3.0.pdf,	GRC-02	Establish a formal, documented, and leadership-sponsored Enterprise Risk Management (ERM) program that includes policies and procedures for identification, evaluation, ownership, treatment, and acceptance of cloud security and privacy risks.	Risk Management Program

GRC-03.1	Are all relevant organizational policies and associated procedures reviewed at least annually, or when a substantial organizational change occurs?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf	GRC-03	Review all relevant organizational policies and associated procedures at least annually or when a substantial change occurs within the organization.	Organizational Policy Reviews	Governance, Risk and Compliance
GRC-04.1	Is an approved exception process mandated by the governance program established and followed whenever a deviation from an established policy occurs?	Yes	Contamos con un proceso de excepción aprobado, tal como lo exige nuestro programa de gobierno. Este proceso se sigue cuando ocurre una desviación de una política establecida. Toda	GRC-04	Establish and follow an approved exception process as mandated by the governance program whenever a deviation from an established policy occurs.	Policy Exception Process	
GRC-05.1	Has an information security program (including programs of all relevant CCM domains) been developed and implemented?	Yes	Contamos con un Sistema de Gestión de Seguridad de la Información (SGSI) alineado con las normas ISO 27001, en la cual estamos certificados. Adjunto:	GRC-05	Develop and implement an Information Security Program, which includes programs for all the relevant domains of the CCM.	Information Security Program	
GRC-06.1	Are roles and responsibilities for planning, implementing, operating, assessing, and improving governance programs defined and documented?	Yes	Nuestra Norma de Roles y Funciones tiene como objetivo determinar las misiones y funciones de los roles que intervienen en el servicio que ofrecemos a los clientes, especificando y	GRC-06	Define and document roles and responsibilities for planning, implementing, operating, assessing, and improving governance programs.	Governance Responsibility Model	
GRC-07.1	Are all relevant standards, regulations, legal/contractual, and statutory requirements applicable to your organization identified and documented?	Yes	Contamos con un registro de Marco Legal Regulatorio / Matriz Cumplimiento donde registramos y hacemos seguimiento de los requerimientos	GRC-07	Identify and document all relevant standards, regulations, legal/contractual, and statutory requirements, which are applicable to your organization.	Information System Regulatory Mapping	
GRC-08.1	Is contact established and maintained with cloud-related special interest groups and other relevant entities?	Yes	INTIZA establece y mantiene contacto con grupos de interés especial y otras entidades relevantes, incluyendo aquellas relacionadas con servicios en	GRC-08	Establish and maintain contact with cloud-related special interest groups and other relevant entities in line with business context.	Special Interest Groups	
HRS-01.1	Are background verification policies and procedures of all new employees (including but not limited to remote employees, contractors, and third parties) established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Nuestra Norma de Contratación de Recursos Humanos (NO-RH-01) establece que los procesos de selección deben velar por la honorabilidad e idoneidad de los colaboradores, considerando su trayectoria y rechazando a quienes carezcan de la idoneidad exigible por sus antecedentes. Para cargos representativos y/o sensibles, solicitamos un certificado de buena	HRS-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for background verification of all new employees (including but not limited to remote employees, contractors, and third parties) according to local laws, regulations, ethics, and contractual constraints and proportional to the data classification to be accessed, the business requirements, and acceptable risk. Review and update the policies and procedures at least annually.	Background Screening Policy and Procedures	
HRS-01.2	Are background verification policies and procedures designed according to local laws, regulations, ethics, and contractual constraints and proportional to the data classification to be accessed, business requirements, and acceptable risk?	Yes	Nuestra Norma de Contratación de Recursos Humanos (NO-RH-01) establece que los procesos de selección deben velar por la honorabilidad e idoneidad de los colaboradores, considerando su trayectoria y rechazando a quienes carezcan de la idoneidad exigible por sus antecedentes. Para cargos representativos y/o sensibles, solicitamos un certificado de buena				
HRS-01.3	Are background verification policies and procedures reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf				
HRS-02.1	Are policies and procedures for defining allowances and conditions for the acceptable use of organizationally-owned or managed assets established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Nuestra empresa garantiza que los colaboradores que utilizan los recursos informáticos suscriban un compromiso de uso adecuado y seguimiento de los lineamientos establecidos . Adjunto: NO-TI-01- Uso de Recursos Informáticos_v2.1.docx.pdf	HRS-02	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for defining allowances and conditions for the acceptable use of organizationally-owned or managed assets. Review and update the policies and procedures at least annually.	Acceptable Use of Technology Policy and Procedures	
HRS-02.2	Are the policies and procedures for defining allowances and conditions for the acceptable use of organizationally-owned or managed assets reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf				
HRS-03.1	Are policies and procedures requiring unattended workspaces to conceal confidential data established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Nuestra Norma de Escritorio y Pantallas Limpas tiene como objetivo evitar el acceso no autorizado a la información en los puestos de trabajo, tanto dentro como fuera de la compañía. Esta norma es aplicable a todo el personal y	HRS-03	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures that require unattended workspaces to not have openly visible confidential data. Review and update the policies and procedures at least annually.	Clean Desk Policy and	

HRS-03.2	Are policies and procedures requiring unattended workspaces to conceal confidential data reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf	HRS-03		Procedures	
HRS-04.1	Are policies and procedures to protect information accessed, processed, or stored at remote sites and locations established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Nuestra política de teletrabajo (NO-TI-02- Teletrabajo_V2.1_2025-05-15.pdf) contempla todas las necesidades técnicas y tecnológicas para el acceso remoto, garantizando configuraciones de acceso seguro, y manteniendo los estándares de adherencia a la información. Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf	HRS-04	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures to protect information accessed, processed or stored at remote sites and locations. Review and update the policies and procedures at least annually.	Remote and Home Working Policy and Procedures	Human Resources
HRS-04.2	Are policies and procedures to protect information accessed, processed, or stored at remote sites and locations reviewed and updated at least annually?	Yes					
HRS-05.1	Are return procedures of organizationally-owned assets by terminated employees established and documented?	Yes		HRS-05	Establish and document procedures for the return of organization-owned assets by terminated employees.	Asset returns	
HRS-06.1	Are procedures outlining the roles and responsibilities concerning changes in employment established, documented, and communicated to all personnel?	Yes	Adjunto: NO-RH-03- Roles y Funciones_v2.0_2024-07-25.pdf	HRS-06	Establish, document, and communicate to all personnel the procedures outlining the roles and responsibilities concerning changes in employment.	Employment Termination	
HRS-07.1	Are employees required to sign an employment agreement before gaining access to organizational information systems, resources, and assets?	Yes	Nuestros empleados deben firmar varios acuerdos que cubren el acceso y la protección de la información de la compañía. Entre ellos, un código de conducta.	HRS-07	Employees sign the employee agreement prior to being granted access to organizational information systems, resources and assets.	Employment Agreement Process	
HRS-08.1	Are provisions and/or terms for adherence to established information governance and security policies included within employment agreements?	Yes	Todos nuestros colaboradores firman un NDA (Acuerdo de Confidencialidad), el código de ética y el documento de inducción de Seguridad de la Información donde se incluyen las políticas de seguridad de la información.	HRS-08	The organization includes within the employment agreements provisions and/or terms for adherence to established information governance and security policies.	Employment Agreement Content	
HRS-09.1	Are employee roles and responsibilities relating to information assets and security documented and communicated?	Yes	Los roles y responsabilidades de los empleados en relación con los activos de información y la seguridad están documentadas y publicadas a todos los empleados.	HRS-09	Document and communicate roles and responsibilities of employees, as they relate to information assets and security.	Personnel Roles and Responsibilities	
HRS-10.1	Are requirements for non-disclosure/confidentiality agreements reflecting organizational data protection needs and operational details identified, documented, and reviewed at planned intervals?	Yes	Todos nuestros colaboradores firman un NDA, el código de ética y el documento de inducción de Seguridad de la Información. Los mismos son revisados y se renueva el compromiso periódicamente.	HRS-10	Identify, document, and review, at planned intervals, requirements for non-disclosure/confidentiality agreements reflecting the organization's needs for the protection of data and operational details.	Non-Disclosure Agreements	
HRS-11.1	Is a security awareness training program for all employees of the organization established, documented, approved, communicated, applied, evaluated and maintained?	Yes	En INTIZA contamos con un programa de entrenamiento y concientización continua sobre ciberseguridad para todos nuestros empleados y contratistas. Adjunto: NO-SI-05- Concientización y Capacitación de Seguridad_v2.1_14-11-2024.pdf	HRS-11	Establish, document, approve, communicate, apply, evaluate and maintain a security awareness training program for all employees of the organization and provide regular training updates.	Security Awareness Training	
HRS-11.2	Are regular security awareness training updates provided?	Yes					
HRS-12.1	Are all employees granted access to sensitive organizational and personal data provided with appropriate security awareness training?	Yes	Las acciones de concientización y capacitación de seguridad son dirigidas a los distintos perfiles de colaboradores y teniendo en cuenta la criticidad y sensibilidad de la información que gestionan. Adjunto: NO-SI-05- Concientización y Capacitación de Seguridad_v2.1_14-11-2024.pdf	HRS-12	Provide all employees with access to sensitive organizational and personal data with appropriate security awareness training and regular updates in organizational procedures, processes, and policies relating to their professional function relative to the organization.	Personal and Sensitive Data Awareness and Training	
HRS-12.2	Are all employees granted access to sensitive organizational and personal data provided with regular updates in procedures, processes, and policies relating to their professional function?	Yes	Nosotros garantizamos que todos los colaboradores que acceden a datos sensibles, tanto organizacionales como personales, reciben actualizaciones periódicas sobre procedimientos, procesos y políticas relevantes para su función profesional. Esto se logra a través de un programa de concientización.				
HRS-13.1	Are employees notified of their roles and responsibilities to maintain awareness and compliance with established policies, procedures, and applicable legal, statutory, or regulatory compliance obligations?	Yes		HRS-13	Make employees aware of their roles and responsibilities for maintaining awareness and compliance with established policies and procedures and applicable legal, statutory, or regulatory compliance obligations.	Compliance User Responsibility	
IAM-01.1	Are identity and access management policies and procedures established, documented, approved, communicated, implemented, applied, evaluated, and maintained?	Yes	Contamos con una Norma de Gestión de Cuentas de Usuarios que define los lineamientos para una administración eficiente y segura de todas las cuentas, incluyendo usuarios estándar y administradores.	IAM-01	Establish, document, approve, communicate, implement, apply, evaluate and maintain policies and procedures for identity and access management. Review and update the policies and procedures at least annually.	Identity and Access Management Policy and	

IAM-01.2	Are identity and access management policies and procedures reviewed and updated at least annually?		Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf			Management Policy and Procedures
IAM-02.1	Are strong password policies and procedures established, documented, approved, communicated, implemented, applied, evaluated, and maintained?	Yes	Nuestra política de contraseñas está documentada y aplicada a todos nuestros empleados y contratistas. Establecemos requisitos de complejidad, como longitud mínima de 8 caracteres, uso de mayúsculas y minúsculas.	IAM-02	Establish, document, approve, communicate, implement, apply, evaluate and maintain strong password policies and procedures. Review and update the policies and procedures at least annually.	Strong Password Policy and Procedures
IAM-02.2	Are strong password policies and procedures reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf			
IAM-03.1	Is system identity information and levels of access managed, stored, and reviewed?	Yes		IAM-03	Manage, store, and review the information of system identities, and level of access.	Identity Inventory
IAM-04.1	Is the separation of duties principle employed when implementing information system access?	Yes		IAM-04	Employ the separation of duties principle when implementing information system access.	Separation of Duties
IAM-05.1	Is the least privilege principle employed when implementing information system access?	Yes		IAM-05	Employ the least privilege principle when implementing information system access.	Least Privilege
IAM-06.1	Is a user access provisioning process defined and implemented which authorizes, records, and communicates data and assets access changes?	Yes	Adjunto: NO-SI-02- Gestión de Cuentas de Usuarios.pdf	IAM-06	Define and implement a user access provisioning process which authorizes, records, and communicates access changes to data and assets.	User Access Provisioning
IAM-07.1	Is a process in place to de-provision or modify the access, in a timely manner, of movers / leavers or system identity changes, to effectively adopt and communicate identity and access management policies?	Yes	En caso de desvinculación de un colaborador, todos sus accesos físicos e informáticos se deshabilitan el mismo día de su partida. Contamos con un control automático que revisa los accesos cada hora para asegurar la inmediatez de estas acciones.	IAM-07	De-provision or respectively modify access of movers / leavers or system identity changes in a timely manner in order to effectively adopt and communicate identity and access management policies.	User Access Changes and Revocation
IAM-08.1	Are reviews and revalidation of user access for least privilege and separation of duties completed with a frequency commensurate with organizational risk tolerance?	Yes	Adjunto: PR-SI-03 Certificación de Derechos de Accesos_2024-08-20_v1.2.pdf	IAM-08	Review and revalidate user access for least privilege and separation of duties with a frequency that is commensurate with organizational risk tolerance.	User Access Review
IAM-09.1	Are processes, procedures, and technical measures for the segregation of privileged access roles defined, implemented, and evaluated such that administrative data access, encryption, key management capabilities, and logging capabilities are distinct and separate?	Yes	Adjunto: NO-SI-25 Gestión de Cuentas de Usuarios Especiales_v1.1_2025-02-27.pdf	IAM-09	Define, implement and evaluate processes, procedures and technical measures for the segregation of privileged access roles such that administrative access to data, encryption and key management capabilities and logging capabilities are distinct and separated.	Segregation of Privileged Access Roles
IAM-10.1	Is an access process defined and implemented to ensure privileged access roles and rights are granted for a limited period?	Yes	Adjunto: NO-SI-25 Gestión de Cuentas de Usuarios Especiales_v1.1_2025-02-27.pdf - PR-SI-03 Certificación de Derechos de Accesos_2024-08-20_v1.2.pdf	IAM-10	Define and implement an access process to ensure privileged access roles and rights are granted for a time limited period, and implement procedures to prevent the culmination of segregated privileged access.	Management of Privileged Access Roles
IAM-10.2	Are procedures implemented to prevent the culmination of segregated privileged access?	Yes	Adjunto: NO-SI-25 Gestión de Cuentas de Usuarios Especiales_v1.1_2025-02-27.pdf - PR-SI-03 Certificación de Derechos de Accesos_2024-08-20_v1.2.pdf			
IAM-11.1	Are processes and procedures for customers to participate, where applicable, in granting access for agreed, high risk as (defined by the organizational risk assessment) privileged access roles defined, implemented and evaluated?	Yes	El cliente administra los accesos de usuarios en la aplicación.	IAM-11	Define, implement and evaluate processes and procedures for customers to participate, where applicable, in the granting of access for agreed, high risk (as defined by the organizational risk assessment) privileged access roles.	CSCs Approval for Agreed Privileged Access Roles
IAM-12.1	Are processes, procedures, and technical measures to ensure the logging infrastructure is "read-only" for all with write access (including privileged access roles) defined, implemented, and evaluated?	Yes	Nuestra Norma de Monitoreo de Eventos y Análisis de Logs establece que las acciones de mantenimiento sobre los registros de eventos de seguridad están restringidas a los administradores de la plataforma. Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-	IAM-12	Define, implement and evaluate processes, procedures and technical measures to ensure the logging infrastructure is read-only for all with write access, including privileged access roles, and that the ability to disable it is controlled through a procedure that ensures the segregation of duties and break glass procedures.	Safeguard Logs Integrity
IAM-12.2	Is the ability to disable the "read-only" configuration of logging infrastructure controlled through a procedure that ensures the segregation of duties and break glass procedures?	Yes				

IAM-13.1	Are processes, procedures, and technical measures that ensure users are identifiable through unique identification (or can associate individuals with user identification usage) defined, implemented, and evaluated?	Yes	Nuestra Política de Seguridad de la Información (PO-SI-01) establece que la identificación de cualquier colaborador debe ser única, personal e intransferible para asegurar la responsabilidad de las acciones efectuadas. Complementando esto, la Norma de Gestión de Cuentas de Todos nuestros colaboradores operan bajo el principio de menor privilegio. Las cuentas de usuario son identificadores únicos y sus credenciales de autenticación son confidenciales e intransferibles. La autenticación multifactor (MFA) está activada para todos los accesos corporativos a través de Microsoft Authenticator y es	IAM-13	Define, implement and evaluate processes, procedures and technical measures that ensure users are identifiable through unique IDs or which can associate individuals to the usage of user IDs.	Uniquely Identifiable Users
IAM-14.1	Are processes, procedures, and technical measures for authenticating access to systems, application, and data assets including multifactor authentication for a least-privileged user and sensitive data access defined, implemented, and evaluated?	Yes	Nuestra Norma de Cifrado de la Información (NO-SI-20) establece explícitamente la generación y obtención de certificados de clave pública y privada para asegurar la gestión de la información crítica. Para la autenticación de usuarios y el acceso a sistemas críticos, empleamos el inicio de sesión único (SSO) a través de Adjunto: - NO-SI-03 - Gestión de Contraseñas_v3.1_2025-11-13.pdf, - NO-SI-02- Gestión de Cuentas de ... En INTIZA, contamos con un sólido marco de gestión para verificar el acceso autorizado a los datos y funciones del sistema, certificado bajo	IAM-14	Define, implement and evaluate processes, procedures and technical measures for authenticating access to systems, application and data assets, including multifactor authentication for at least privileged user and sensitive data access. Adopt digital certificates or alternatives which achieve an equivalent level of security for system identities.	Strong Authentication
IAM-14.2	Are digital certificates or alternatives that achieve an equivalent security level for system identities adopted?	Yes				
IAM-15.1	Are processes, procedures, and technical measures for the secure management of passwords defined, implemented, and evaluated?	Yes		IAM-15	Define, implement and evaluate processes, procedures and technical measures for the secure management of passwords.	Passwords Management
IAM-16.1	Are processes, procedures, and technical measures to verify access to data and system functions authorized, defined, implemented, and evaluated?	Yes		IAM-16	Define, implement and evaluate processes, procedures and technical measures to verify access to data and system functions is authorized.	Authorization Mechanisms
IPY-01.1	Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for communications between application services (e.g., APIs)?	Yes		IPY-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for interoperability and portability including requirements for: a. Communications between application interfaces b. Information processing interoperability c. Application development portability d. Information/Data exchange, usage, portability, integrity, and persistence Review and update the policies and procedures at least annually.	Interoperability and Portability Policy and Procedures
IPY-01.2	Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for information processing interoperability?					
IPY-01.3	Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for application development portability?	NA	Intiza es un aplicación SaaS.			
IPY-01.4	Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for information/data exchange, usage, portability, integrity, and persistence?	Yes	Para el intercambio de datos, exigimos el cifrado de información sensible y datos personales tanto en reposo como en tránsito, utilizando algoritmos fuertes como AES de 256 bits, incluso con proveedores externos. Adjunto: NO-SI-20 Cifrado de la Información - NO-SI-23 Seguridad en Telecomunicaciones			
IPY-01.5	Are interoperability and portability policies and procedures reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf			

IPY-02.1	Are CSCs able to programmatically retrieve their data via an application interface(s) to enable interoperability and portability?	Yes	La aplicación de INTIZA permite a los usuarios generar un backup de sus datos en cualquier momento que lo requieran.	IPY-02	Provide application interface(s) to CSCs so that they programmatically retrieve their data to enable interoperability and portability.	Application Interface Availability
IPY-03.1	Are cryptographically secure and standardized network protocols implemented for the management, import, and export of data?	Yes	Implementamos protocolos de red estandarizados y criptográficamente seguros para la gestión, importación y exportación de datos. Ciframos los datos.	IPY-03	Implement cryptographically secure and standardized network protocols for the management, import and export of data.	Secure Interoperability and Portability Management
IPY-04.1	Do agreements include provisions specifying CSC data access upon contract termination, and have the following? a. Data format b. Duration data will be stored c. Scope of the data retained and made available to the CSCs d. Data deletion policy	Yes	Nuestros acuerdos con los Clientes incluyen cláusulas específicas sobre el acceso y gestión de sus datos tras la finalización del contrato. a) Formato de los datos: La aplicación permite al cliente generar un respaldo de sus datos en cualquier momento, asegurando que puedan obtener una copia en un formato de backup estándar Adjunto: - NO-SI-23 Seguridad en Telecomunicaciones.pdf	IPY-04	Agreements must include provisions specifying CSCs access to data upon contract termination and will include: a. Data format b. Length of time the data will be stored c. Scope of the data retained and made available to the CSCs d. Data deletion policy	Data Portability Contractual Obligations
IVS-01.1	Are infrastructure and virtualization security policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?	Yes		IVS-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for infrastructure and virtualization security. Review and update the policies and procedures at least annually.	Infrastructure and Virtualization Security Policy and Procedures
IVS-01.2	Are infrastructure and virtualization security policies and procedures reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf			
IVS-02.1	Is resource availability, quality, and capacity planned and monitored in a way that delivers required system performance, as determined by the business?	Yes	Nuestra Norma de Gestión de Demanda y Capacidad (NO-SI-14) establece los lineamientos para proveer la capacidad necesaria de los sistemas de información, tanto para los entornos de producción como de desarrollo.	IVS-02	Plan and monitor the availability, quality, and adequate capacity of resources in order to deliver the required system performance as determined by the business.	Capacity and Resource Planning
IVS-03.1	Are communications between environments monitored?	Yes	La Norma de Monitoreos de Eventos y Análisis de Loga (NO-SI-12) detalla los lineamientos para registrar eventos y generar trazabilidad sobre las operaciones en sistemas de información y operativos, incluyendo dispositivos de comunicación y seguridad. Adjunto: Arlinton		Monitor, encrypt and restrict communications between environments to only authenticated and authorized connections, as justified by the business. Review these configurations at least annually, and support them by a documented justification of all allowed services, protocols, ports, and compensating controls.	
IVS-03.2	Are communications between environments encrypted?	Yes	- NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf, - NO-SI-23 Seguridad en Telecomunicaciones_2024-12-30_v2.1.pdf			
IVS-03.3	Are communications between environments restricted to only authenticated and authorized connections, as justified by the business?	Yes	En INTIZA, todas las comunicaciones entre nuestros ambientes están estrictamente restringidas a conexiones autenticadas y autorizadas, siempre justificadas por la necesidad del negocio. Implementamos una sólida separación lógica y física para entornos de desarrollo, pruebas y producción tal	IVS-03		Network Security
IVS-03.4	Are network configurations reviewed at least annually?	Yes				
IVS-03.5	Are network configurations supported by the documented justification of all allowed services, protocols, ports, and compensating controls?	Yes	Nuestra Norma de Seguridad en Telecomunicaciones (NO-SI-23) establece las pautas para el diseño e implementación de redes, identificando zonas y servicios permitidos para asegurar una protección robusta.			
IVS-04.1	Is every host and guest OS, hypervisor, or infrastructure control plane hardened (according to their respective best practices) and supported by technical controls as part of a security baseline?	Yes	Utilizamos la suite de Microsoft (Sentinel, Defender for Endpoint, Defender for Cloud, WAF, Firewalls, etc.) para proteger nuestra infraestructura y aplicaciones contra ciberamenazas Adjunto: NO-SI-23 Seguridad en Telecomunicaciones_2024-12-30_v2.1.pdf	IVS-04	Harden host and guest OS, hypervisor or infrastructure control plane according to their respective best practices, and supported by technical controls, as part of a security baseline.	OS Hardening and Base Controls
IVS-05.1	Are production and non-production environments separated?	Yes	Adjunto: NO-SI-09 - Gestión de ambientes_2024-07-10_v1.2.pdf	IVS-05	Separate production and non-production environments.	Production and Non-Production Environments

IVS-06.1	Are applications and infrastructures designed, developed, deployed, and configured such that CSP and CSC (tenant) user access and intra-tenant access is appropriately segmented, segregated, monitored, and restricted from other tenants?	Yes	Implementamos una separación lógica de datos para cada cliente en nuestras instancias de bases de datos compartidas, con la opción de instancias dedicadas si se requiere. Para el acceso de usuarios, tanto internos como de clientes, aplicamos el principio de menor privilegio. otorgando Inltza es una aplicación SaaS. Ya está operando en la nube, no requiere migración.	IVS-06	Design, develop, deploy and configure applications and infrastructures such that CSP and CSC (tenant) user access and intra-tenant access is appropriately segmented and segregated, monitored and restricted from other tenants.	Segmentation and Segregation	Logging and Monitoring
IVS-07.1	Are secure and encrypted communication channels including only up-to-date and approved protocols used when migrating servers, services, applications, or data to cloud environments?	NA		IVS-07	Use secure and encrypted communication channels when migrating servers, services, applications, or data to cloud environments. Such channels must include only up-to-date and approved protocols.	Migration to Cloud Environments	
IVS-08.1	Are high-risk environments identified and documented?	Yes	Los entornos de alto riesgo son identificados y documentados de manera sistemática. Contamos con una	IVS-08	Identify and document high-risk environments.	Network Architecture Documentation	
IVS-09.1	Are processes, procedures, and defense-in-depth techniques defined, implemented, and evaluated for protection, detection, and timely response to network-based attacks?	Yes	Nuestra estrategia de protección incluye la implementación de firewalls que median todo el tráfico entrante y saliente, configurados según estándares documentados para prevenir ataques internos y externos. Todos nuestros equipos están protegidos con	IVS-09	Define, implement and evaluate processes, procedures and defense-in-depth techniques for protection, detection, and timely response to network-based attacks.	Network Defense	
LOG-01.1	Are logging and monitoring policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for logging and monitoring. Review and update the policies and procedures at least annually.	Logging and Monitoring Policy and Procedures	
LOG-01.2	Are policies and procedures reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf				
LOG-02.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to ensure audit log security and retention?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-02	Define, implement and evaluate processes, procedures and technical measures to ensure the security and retention of audit logs.	Audit Logs Protection	
LOG-03.1	Are security-related events identified and monitored within applications and the underlying infrastructure?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-03	Identify and monitor security-related events within applications and the underlying infrastructure. Define and implement a system to generate alerts to responsible stakeholders based on such events and corresponding metrics.	Security Monitoring and Alerting	
LOG-03.2	Is a system defined and implemented to generate alerts to responsible stakeholders based on security events and their corresponding metrics?	Yes	Para el monitoreo de bases de datos, nuestra Norma de Gestión de Demanda y Capacidad (NO-SI-14) indica que si un evento se sale del rango establecido, el sistema automáticamente emite un correo de alerta a un grupo predefinido . Nuestro software de Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd				
LOG-04.1	Is access to audit logs restricted to authorized personnel, and are records maintained to provide unique access accountability?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-04	Restrict audit logs access to authorized personnel and maintain records that provide unique access accountability.	Audit Logs Access and Accountability	
LOG-05.1	Are security audit logs monitored to detect activity outside of typical or expected patterns?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-05	Monitor security audit logs to detect activity outside of typical or expected patterns. Establish and follow a defined process to review and take appropriate and timely actions on detected anomalies.	Audit Logs Monitoring and Response	
LOG-05.2	Is a process established and followed to review and take appropriate and timely actions on detected anomalies?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22				
LOG-06.1	Is a reliable time source being used across all relevant information processing systems?	Yes		LOG-06	Use a reliable time source across all relevant information processing systems.	Clock Synchronization	
LOG-07.1	Are logging requirements for information meta/data system events established, documented, and implemented?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-07	Establish, document and implement which information meta/data system events should be logged. Review and update the scope at least annually or whenever there is a change in the threat environment.	Logging Scope	
LOG-07.2	Is the scope reviewed and updated at least annually, or whenever there is a change in the threat environment?	Yes					

LOG-08.1	Are audit records generated, and do they contain relevant security information?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-08	Generate audit records containing relevant security information.	Log Records	Security Incident Management, E-Discovery, & Cloud Forensics
LOG-09.1	Does the information system protect audit records from unauthorized access, modification, and deletion?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-09	The information system protects audit records from unauthorized access, modification, and deletion.	Log Protection	
LOG-10.1	Are monitoring and internal reporting capabilities established to report on cryptographic operations, encryption, and key management policies, processes, procedures, and controls?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd	LOG-10	Establish and maintain a monitoring and internal reporting capability over the operations of cryptographic, encryption and key management policies, processes, procedures, and controls.	Encryption Monitoring and Reporting	
LOG-11.1	Are key lifecycle management events logged and monitored to enable auditing and reporting on cryptographic keys' usage?	Yes		LOG-11	Log and monitor key lifecycle management events to enable auditing and reporting on usage of cryptographic keys.	Transaction/Activity Logging	
LOG-12.1	Is physical access logged and monitored using an auditable access control system?	Yes	El ingreso de todo el personal, tanto interno como externo, se registra y controla Adjunto: NO-RH-02 Acceso y Control Físico_v2.1_2025-02-28.pdf,	LOG-12	Monitor and log physical access using an auditable access control system.	Access Control Logs	
LOG-13.1	Are processes and technical measures for reporting monitoring system anomalies and failures defined, implemented, and evaluated?	Yes	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24.pd - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf	LOG-13	Define, implement and evaluate processes, procedures and technical measures for the reporting of anomalies and failures of the monitoring system and provide immediate notification to the accountable party.	Failures and Anomalies Reporting	
LOG-13.2	Are accountable parties immediately notified about anomalies and failures?	Yes	Las partes responsables son notificadas de inmediato sobre anomalías y fallas a través de nuestros procesos definidos. Adjunto: - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf				
SEF-01.1	Are policies and procedures for security incident management, e-discovery, and cloud forensics established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Adjunto: - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf	SEF-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for Security Incident Management, E-Discovery, and Cloud Forensics. Review and update the policies and procedures at least annually.	Security Incident Management Policy and Procedures	
SEF-01.2	Are policies and procedures reviewed and updated annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf				
SEF-02.1	Are policies and procedures for timely management of security incidents established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Adjunto: - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf	SEF-02	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for the timely management of security incidents. Review and update the policies and procedures at least annually.	Service Management Policy and Procedures	
SEF-02.2	Are policies and procedures for timely management of security incidents reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf				
SEF-03.1	Is a security incident response plan that includes relevant internal departments, impacted CSCs, and other business-critical relationships (such as supply-chain) established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Adjunto: - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf	SEF-03	'Establish, document, approve, communicate, apply, evaluate and maintain a security incident response plan, which includes but is not limited to: relevant internal departments, impacted CSCs, and other business critical relationships (such as supply-chain) that may be impacted.'	Incident Response Plans	
SEF-04.1	Is the security incident response plan tested and updated for effectiveness, as necessary, at planned intervals or upon significant organizational or environmental changes?	Yes	En INTIZA, nuestro plan de respuesta a incidentes de seguridad se integra dentro de una robusta Política de Continuidad de Procesamiento de Datos, la cual es probada y actualizada periódicamente para garantizar su efectividad	SEF-04	Test and update as necessary incident response plans at planned intervals or upon significant organizational or environmental changes for effectiveness.	Incident Response Testing	
SEF-05.1	Are information security incident metrics established and monitored?	Yes		SEF-05	Establish and monitor information security incident metrics.	Incident Response Metrics	
SEF-06.1	Are processes, procedures, and technical measures supporting business processes to triage security-related events defined, implemented, and evaluated?	Yes	Adjunto: - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf	SEF-06	Define, implement and evaluate processes, procedures and technical measures supporting business processes to triage security-related events.	Event Triage Processes	
SEF-07.1	Are processes, procedures, and technical measures for security breach notifications defined and implemented?	Yes	Adjunto: - NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf	SEF-07	Define and implement, processes, procedures and technical measures for security breach notifications. Report security breaches and assumed security breaches including any relevant supply chain breaches, as per applicable SLAs, laws and regulations.	Security Breach Notification	

SEF-07.2	Are security breaches and assumed security breaches reported (including any relevant supply chain breaches) as per applicable SLAs, laws, and regulations?	Yes	INTIZA cuenta con un proceso formal y documentado para la gestión de incidentes de seguridad que abarca la detección, registro, resolución, verificación y comunicación. Adjunto: NO-SI-10- Gestión de Incidentes de Seguridad v2.1_2024-06-22.pdf	SEF-07		Security Breach Notification	
SEF-08.1	Are points of contact maintained for applicable regulation authorities, national and local law enforcement, and other legal jurisdictional authorities?	Yes	En INTIZA mantenemos puntos de contacto con las autoridades reguladoras, las fuerzas del orden nacionales y locales, y otras autoridades jurisdiccionales pertinentes	SEF-08	Maintain points of contact for applicable regulation authorities, national and local law enforcement, and other legal jurisdictional authorities.	Points of Contact Maintenance	
STA-01.1	Are policies and procedures implementing the shared security responsibility model (SSRM) within the organization established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	Para entornos de nube, la Norma de Seguridad Cloud (NO-SI-27) declara que el uso de servicios en la nube implica una responsabilidad compartida entre INTIZA y el proveedor. Sin embargo, enfatiza que INTIZA es el principal responsable de la seguridad de la información almacenada y procesada en su entorno cloud.	STA-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for the application of the Shared Security Responsibility Model (SSRM) within the organization. Review and update the policies and procedures at least annually.	SSRM Policy and Procedures	
STA-01.2	Are the policies and procedures that apply the SSRM reviewed and updated annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf				
STA-02.1	Is the SSRM applied, documented, implemented, and managed throughout the supply chain for the cloud service offering?	Yes	Adjunto: - NO-SI-07- Contratación, Seguridad y Control de Proveedores_v2.1_2024-10-15.pdf, - NO-SI-27- Norma de Seguridad	STA-02	Apply, document, implement and manage the SSRM throughout the supply chain for the cloud service offering.	SSRM Supply Chain	
STA-03.1	Is the CSC given SSRM guidance detailing information about SSRM applicability throughout the supply chain?	Yes	Adjunto: - NO-SI-07- Contratación, Seguridad y Control de Proveedores_v2.1_2024-10-15.pdf, - NO-SI-27- Norma de Seguridad	STA-03	Provide SSRM Guidance to the CSC detailing information about the SSRM applicability throughout the supply chain.	SSRM Guidance	
STA-04.1	Is the shared ownership and applicability of all CSA CCM controls delineated according to the SSRM for the cloud service offering?	Yes		STA-04	Delineate the shared ownership and applicability of all CSA CCM controls according to the SSRM for the cloud service offering.	SSRM Control Ownership	
STA-05.1	Is SSRM documentation for all cloud services the organization uses reviewed and validated?	Yes		STA-05	Review and validate SSRM documentation for all cloud services offerings the organization uses.	SSRM Documentation Review	
STA-06.1	Are the portions of the SSRM the organization is responsible for implemented, operated, audited, or assessed?	Yes	INTIZA asume la responsabilidad principal por la seguridad de la información almacenada, transmitida y procesada en nuestro entorno cloud.	STA-06	Implement, operate, and audit or assess the portions of the SSRM which the organization is responsible for.	SSRM Control Implementation	
STA-07.1	Is an inventory of all supply chain relationships developed and maintained?	Yes		STA-07	Develop and maintain an inventory of all supply chain relationships.	Supply Chain Inventory	Supply Chain Management, Transparency, and Accountability
STA-08.1	Are risk factors associated with all organizations within the supply chain periodically reviewed by CSPs?	Yes	Adjunto: NO-SI-04- Gestión de Riesgo del SGSI_2024-11-21_v3.0.pdf	STA-08	CSPs periodically review risk factors associated with all organizations within their supply chain.	Supply Chain Risk Management	
STA-09.1	Do service agreements between CSPs and CSCs (tenants) incorporate at least the following mutually agreed upon provisions and/or terms? • Scope, characteristics, and location of business relationship and services offered • Information security requirements (including SSRM) • Change management process • Logging and monitoring capability • Incident management and communication procedures • Right to audit and third-party assessment • Service termination • Interoperability and portability requirements • Data privacy	Yes	Nuestros acuerdos de servicio con los Clientes Corporativos incorporan explícitamente provisiones clave que garantizan un marco de seguridad y transparencia robusto. Adjunto: - NO-SI-07- Contratación, Seguridad y Control de Proveedores_v2.1_2024-10-15.pdf, - NO-SI-27- Norma de Seguridad Cloud.pdf	STA-09	Service agreements between CSPs and CSCs (tenants) must incorporate at least the following mutually-agreed upon provisions and/or terms: • Scope, characteristics and location of business relationship and services offered • Information security requirements (including SSRM) • Change management process • Logging and monitoring capability • Incident management and communication procedures • Right to audit and third party assessment • Service termination • Interoperability and portability requirements • Data privacy	Primary Service and Contractual Agreement	
STA-10.1	Are supply chain agreements between CSPs and CSCs reviewed at least annually?	Yes		STA-10	Review supply chain agreements between CSPs and CSCs at least annually.	Supply Chain Agreement Review	
STA-11.1	Is there a process for conducting internal assessments at least annually to confirm the conformance and effectiveness of standards, policies, procedures, and SLA activities?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adicionalmente realizamos auditorías internas y externas que verifican el cumplimiento de todos el sistema de	STA-11	Define and implement a process for conducting internal assessments to confirm conformance and effectiveness of standards, policies, procedures, and service level agreement activities at least annually.	Internal Compliance Testing	

STA-12.1	Are policies that require all supply chain CSPs to comply with information security, confidentiality, access control, privacy, audit, personnel policy, and service level requirements and standards implemented?	Yes	Adjunto: O-SI-07- Contratación, Seguridad y Control de Proveedores_v2.1_2024-10-15.pdf	STA-12	Implement policies requiring all CSPs throughout the supply chain to comply with information security, confidentiality, access control, privacy, audit, personnel policy and service level requirements and standards.	Supply Chain Service Agreement Compliance	Threat & Vulnerability Management
STA-13.1	Are supply chain partner IT governance policies and procedures reviewed periodically?	Yes		STA-13	Periodically review the organization's supply chain partners' IT governance policies and procedures.	Supply Chain Governance Review	
STA-14.1	Is a process to conduct periodic security assessments for all supply chain organizations defined and implemented?	Yes	Adjunto: O-SI-07- Contratación, Seguridad y Control de Proveedores_v2.1_2024-10-15.pdf	STA-14	Define and implement a process for conducting security assessments periodically for all organizations within the supply chain.	Supply Chain Data Security Assessment	
TVM-01.1	Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained to identify, report, and prioritize the remediation of vulnerabilities to protect systems against vulnerability exploitation?	Yes	La Norma de Gestión de Vulnerabilidades y Parches (NO-SI-13) establece los lineamientos para identificar, detectar, clasificar y priorizar las vulnerabilidades con el fin de monitorear su remediación y mitigación	TVM-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures to identify, report and prioritize the remediation of vulnerabilities, in order to protect systems against vulnerability exploitation. Review and update the policies and procedures at least annually.	Threat and Vulnerability Management Policy and Procedures	
TVM-01.2	Are threat and vulnerability management policies and procedures reviewed and updated at least annually?	Yes	Todas nuestras políticas y normas se revisan y actualizan de acuerdo a nuestra norma de gestión documental. Adjunto: NO-SI-01- Gestión Documental del SGSI_v3.1_2024-06-14.pdf				
TVM-02.1	Are policies and procedures to protect against malware on managed assets established, documented, approved, communicated, applied, evaluated, and maintained?	Yes	La Norma de Software Malicioso (NO-TI-03) define los lineamientos generales y requisitos específicos para esta protección, abarcando todos los sistemas informáticos que soportan nuestros procesos de negocio. Adjunto:	TVM-02	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures to protect against malware on managed assets. Review and update the policies and procedures at least annually.	Malware Protection Policy and Procedures	
TVM-02.2	Are asset management and malware protection policies and procedures reviewed and updated at least annually?	Yes					
TVM-03.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to enable scheduled and emergency responses to vulnerability identifications (based on the identified risk)?	Yes		TVM-03	Define, implement and evaluate processes, procedures and technical measures to enable both scheduled and emergency responses to vulnerability identifications, based on the identified risk.	Vulnerability Remediation Schedule	
TVM-04.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to update detection tools, threat signatures, and compromise indicators weekly (or more frequent) basis?			TVM-04	Define, implement and evaluate processes, procedures and technical measures to update detection tools, threat signatures, and indicators of compromise on a weekly, or more frequent basis.	Detection Updates	
TVM-05.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to identify updates for applications that use third-party or open-source libraries (according to the organization's vulnerability management policy)?			TVM-05	Define, implement and evaluate processes, procedures and technical measures to identify updates for applications which use third party or open source libraries according to the organization's vulnerability management policy.	External Library Vulnerabilities	
TVM-06.1	Are processes, procedures, and technical measures defined, implemented, and evaluated for periodic, independent, third-party penetration testing?			TVM-06	Define, implement and evaluate processes, procedures and technical measures for the periodic performance of penetration testing by independent third parties.	Penetration Testing	
TVM-07.1	Are processes, procedures, and technical measures defined, implemented, and evaluated for vulnerability detection on organizationally managed assets at least monthly?			TVM-07	Define, implement and evaluate processes, procedures and technical measures for the detection of vulnerabilities on organizationally managed assets at least monthly.	Vulnerability Identification	
TVM-08.1	Is vulnerability remediation prioritized using a risk-based model from an industry-recognized framework?			TVM-08	Use a risk-based model for effective prioritization of vulnerability remediation using an industry recognized framework.	Vulnerability Prioritization	
TVM-09.1	Is a process defined and implemented to track and report vulnerability identification and remediation activities that include stakeholder notification?			TVM-09	Define and implement a process for tracking and reporting vulnerability identification and remediation activities that includes stakeholder notification.	Vulnerability Management Reporting	
TVM-10.1	Are metrics for vulnerability identification and remediation established, monitored, and reported at defined intervals?			TVM-10	Establish, monitor and report metrics for vulnerability identification and remediation at defined intervals.	Vulnerability Management Metrics	

UEM-01.1	Are policies and procedures established, documented, approved, communicated, applied, evaluated, and maintained for all endpoints?			UEM-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for all endpoints. Review and update the policies and procedures at least annually.	Endpoint Devices Policy and Procedures	Universal Endpoint Management
UEM-01.2	Are universal endpoint management policies and procedures reviewed and updated at least annually?						
UEM-02.1	Is there a defined, documented, applicable and evaluated list containing approved services, applications, and the sources of applications (stores) acceptable for use by endpoints when accessing or storing organization-managed data?			UEM-02	Define, document, apply and evaluate a list of approved services, applications and sources of applications (stores) acceptable for use by endpoints when accessing or storing organization-managed data.	Application and Service Approval	
UEM-03.1	Is a process defined and implemented to validate endpoint device compatibility with operating systems and applications?			UEM-03	Define and implement a process for the validation of the endpoint device's compatibility with operating systems and applications.	Compatibility	
UEM-04.1	Is an inventory of all endpoints used and maintained to store and access company data?			UEM-04	Maintain an inventory of all endpoints used to store and access company data.	Endpoint Inventory	
UEM-05.1	Are processes, procedures, and technical measures defined, implemented and evaluated, to enforce policies and controls for all endpoints permitted to access systems and/or store, transmit, or process organizational data?			UEM-05	Define, implement and evaluate processes, procedures and technical measures to enforce policies and controls for all endpoints permitted to access systems and/or store, transmit, or process organizational data.	Endpoint Management	
UEM-06.1	Are all relevant interactive-use endpoints configured to require an automatic lock screen?			UEM-06	Configure all relevant interactive-use endpoints to require an automatic lock screen.	Automatic Lock Screen	
UEM-07.1	Are changes to endpoint operating systems, patch levels, and/or applications managed through the organizational change management process?			UEM-07	Manage changes to endpoint operating systems, patch levels, and/or applications through the company's change management processes.	Operating Systems	
UEM-08.1	Is information protected from unauthorized disclosure on managed endpoints with storage encryption?			UEM-08	Protect information from unauthorized disclosure on managed endpoint devices with storage encryption.	Storage Encryption	
UEM-09.1	Are anti-malware detection and prevention technology services configured on managed endpoints?			UEM-09	Configure managed endpoints with anti-malware detection and prevention technology and services.	Anti-Malware Detection and Prevention	
UEM-10.1	Are software firewalls configured on managed endpoints?			UEM-10	Configure managed endpoints with properly configured software firewalls.	Software Firewall	
UEM-11.1	Are managed endpoints configured with data loss prevention (DLP) technologies and rules per a risk assessment?			UEM-11	Configure managed endpoints with Data Loss Prevention (DLP) technologies and rules in accordance with a risk assessment.	Data Loss Prevention	
UEM-12.1	Are remote geolocation capabilities enabled for all managed mobile endpoints?			UEM-12	Enable remote geo-location capabilities for all managed mobile endpoints.	Remote Locate	
UEM-13.1	Are processes, procedures, and technical measures defined, implemented, and evaluated to enable remote company data deletion on managed endpoint devices?			UEM-13	Define, implement and evaluate processes, procedures and technical measures to enable the deletion of company data remotely on managed endpoint devices.	Remote Wipe	
UEM-14.1	Are processes, procedures, and technical and/or contractual measures defined, implemented, and evaluated to maintain proper security of third-party endpoints with access to organizational assets?			UEM-14	Define, implement and evaluate processes, procedures and technical and/or contractual measures to maintain proper security of third-party endpoints with access to organizational assets.	Third-Party Endpoint Security Posture	

End of Standard

© Copyright 2024 Cloud Security Alliance - All rights reserved. You may download, store, display on your computer, view, print, and link to the Cloud Security Alliance "Consensus Assessments Initiative Questionnaire (CAIQ) Version 4.0.3" at <http://www.cloudsecurityalliance.org> subject to the following: (a) the Consensus Assessments Initiative Questionnaire v4.0.3 may be used solely for your personal, informational, non-commercial use; (b) the Consensus Assessments Initiative Questionnaire v4.0.3 may not be modified or altered in any way; (c) the Consensus Assessments Initiative Questionnaire v4.0.3 may not be redistributed; and (d) the trademark, copyright or other notices may not be removed. You may quote portions of the Consensus Assessments Initiative Questionnaire v4.0.3 as permitted by the Fair Use provisions of the United States Copyright Act, provided that you attribute the portions to the Cloud Security Alliance Consensus Assessments Initiative Questionnaire Version 4.0.3. If you are interested in obtaining a license to this #material for other usages not addresses in the copyright notice, please contact info@cloudsecurityalliance.org.